

西南交通大学



《网络空间安全技术》 课程设计任务书

题目 5：Web 应用安全防护与 WAF 规则验证系统

适用学号尾号：5

完成方式：单人完成 | 实验环境：本地授权环境 | 核心要求：有实现、有数据、有流程图、有验证

重要：课程设计重点是“技术应用 + 可运行验证 + 流程图解释”，不得只提交概念性介绍或 GPT 生成的空泛报告。

一、课程设计信息

项目	说明
课程名称	网络空间安全技术
完成方式	单人完成
题目编号	题目 5
适用学生	学号末尾为 5 的学生
课程设计题目	Web 应用安全防护与 WAF 规则验证系统
核心定位	技术应用型课程设计，不接受纯理论综述式报告

二、项目背景

Web 应用常见风险包括 SQL 注入、XSS、恶意参数提交、路径访问异常等。本题要求学生搭建一个本地 Web 应用，并配置简化版 WAF 规则或自写请求过滤模块，对异常请求进行检测和拦截。

三、安全与合规要求

- 所有实验必须在本机虚拟机、Docker 本地靶场、教师授权平台或自行搭建的离线环境中完成。
- 严禁扫描公网、校园网真实服务器、他人设备或未授权系统。
- 严禁传播真实恶意代码、木马、勒索软件，严禁对真实账号、真实网站开展攻击测试。
- 报告中必须写明：本实验仅在授权环境或本地虚拟环境中完成，未对真实第三方系统造成影响。

四、技术应用重点

- Web 请求过滤
- 输入校验
- WAF 规则
- 日志审计
- 拦截策略
- 安全验证

五、实验环境建议

- Flask / Spring Boot / PHP
- Nginx
- ModSecurity 可选

- 自写过滤中间件
- 本地测试环境

六、主要任务

1. 搭建一个简单 Web 应用。
2. 设计若干输入点。
3. 配置或编写请求过滤规则。
4. 检测异常参数。
5. 记录被拦截请求。
6. 输出防护测试报告。

七、必须实现的功能

1. 正常请求允许访问。
2. 异常参数请求被识别。
3. 记录请求来源、时间、参数、规则编号。
4. 对不同规则进行分类。
5. 输出拦截日志。
6. 给出误报分析。

八、规则或事件示例

规则编号	防护方向
R001	SQL 注入特征过滤
R002	XSS 特征过滤
R003	路径穿越特征过滤
R004	高频请求限制
R005	非法 User-Agent 识别

九、流程图硬性要求

本题至少绘制 3 张流程图。下列示例图仅用于说明深度要求，学生在正式报告中应结合本人实现重新绘制，并能在答辩时解释每个判断分支对应的代码、规则或实验步骤。

1. Web 请求处理流程图：用户请求、WAF 检查、正常请求放行、异常请求拦截。
2. 规则匹配流程图：读取请求参数、遍历规则、判断命中、记录规则编号。
3. 防护验证流程图：构造正常请求、构造异常请求、观察响应、分析日志。

流程图示例 1：Web 请求处理流程图



图 1 Web 请求处理流程图。正式报告需替换为本人实现对应的流程图。

流程图示例 2：规则匹配流程图



图 2 规则匹配流程图。正式报告需替换为本人实现对应的流程图。

流程图示例 3：防护验证流程图

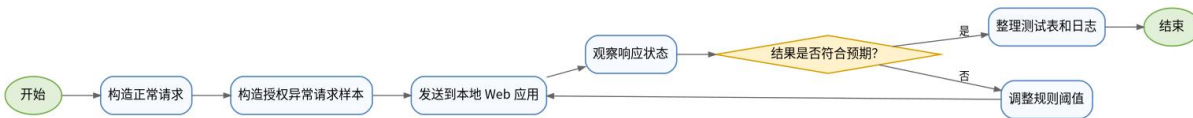


图 3 防护验证流程图。正式报告需替换为本人实现对应的流程图。

十、防止简单被 AI 复现的要求

报告必须体现本人真实实验环境、本人生成的数据、本人设置的规则或阈值。

- 自己设计的 Web 页面截图。
- 自己编写或配置的规则文件。
- 至少 5 条正常请求样本。
- 至少 5 条被拦截请求样本。
- 拦截日志截图。
- 误报和漏报分析。

十一、统一提交内容

- 课程设计报告：项目背景、需求分析、技术方案、核心模块、实验过程、测试结果、问题分析与改进方向。
- 至少 3 张流程图：系统总体流程图、核心技术处理流程图、测试与处置流程图。流程图必须包含判断条件、输入输出和异常路径。
- 实验截图与日志：环境截图、配置截图、运行截图、测试截图、日志或数据文件截图。
- 代码或配置文件：Python、Java、Go、Shell、Docker Compose、Nginx 配置、规则文件等均可，必须能运行。

- 演示或答辩：现场能够修改一个参数、规则、阈值、目录、端口或测试数据，并重新运行验证。

十二、报告模板建议（根据实际情况修改）

1. 课程设计题目
2. 项目背景
3. 实验环境
4. 需求分析
5. 技术方案
6. 系统总体流程图
7. 核心模块流程图
8. 测试与处置流程图
9. 系统实现
10. 实验数据
11. 测试用例
12. 运行结果
13. 问题与改进
14. 总结
15. 附录：代码、配置、日志、截图

十二、特别强调

本课程设计不是写一篇“网络安全介绍文章”，而是完成一个小型安全技术应用项目。必须体现：有场景、有数据、有流程、有规则、有实现、有测试、有结果、有分析。

- 流程图必须和实际实现对应。
- 报告截图必须来自本人实验。
- 安全规则必须由本人设计或修改。
- 测试数据必须具有个性化。
- 答辩时必须能解释代码、规则和流程图之间的关系。